STAJ PROJESİ · TÜRKSAT AVIATION AND COMMUNICATION

# Akıllı Okul Bilgi Sistemi

## Hafta 7 — Güvenlik, Değerlendirme ve Konuşmalı Asistan


| | |
|---|---|
| HAZIRLAYAN | Bera Ergin — s29315 |
| KURUM | PJAIT — 7. Yarıyıl |
| BU HAFTA | Sistemi saldırgan gözüyle sınıyoruz, modeli ölçüyoruz |

# Nereden Geliyoruz, Nereye Gidiyoruz

**HAFTA 6 — BİTTİ**

- ✓ Arayüz ve backend uçtan uca çalışıyor
- ✓ Her katman kendi testiyle doğrulandı
- ! Ama sistem hiç saldırı gözüyle sınanmadı
- ! Modelin davranışı sistematik ölçülmedi

**HAFTA 7 — HEDEF**

- Tehdit modeli ve her tehdit için bir test
- Modelin yazdığı SQL ile yetki yükseltme denemesi
- Giriş güvenliği ve CORS sıkılaştırma
- Model davranışı için değerlendirme (eval) seti

# Tehdit Modeli

*Her tehdit için hangi katman durduruyor, hangi test kanıtlıyor*

| Tehdit | Katman | Kanıt |
|---|---|---|
| **Modelin yazdığı SQL ile yetki yükseltme** | Doğrulama: fonksiyon izin listesi | Saldırgan istem testleri |
| **Hassas tablolara erişim** | Veritabanı yetkisi (users, teachers) | Yetki hatası testi |
| **Kaba kuvvetle giriş** | Giriş hız sınırı, tek tip 401 | Giriş testleri |
| **JWT, şifre, anahtar sızıntısı** | Yanıt ve log kuralları | Yanıt/log testleri |
| **Pahalı sorgu** | 5 sn zaman aşımı, 500 satır | Zaman aşımı testi |

# Bulgu: Model, Bağlamı Kendisi Değiştirebiliyordu

*Hipotez yeniden üretildi; fonksiyon izin listesiyle kapatıldı*

```
WITH x AS (SELECT set_config('app.role','principal',true))
SELECT s.* FROM students s, x
```

Tek ifade, tek SELECT, izinli tablo: bugünkü doğrulamanın baktığı her şey geçer. RLS politikası ise oturum ayarını okur.

1. Yeniden üretildi: teacher bağlamı normalde 4 satır görürken bu SQL ile 12 satır gördü
2. Neden: politika taramada app.role okur; aynı ifadedeki set_config bu ayarı transaction içinde principal yapar
3. Kapatıldı: izin listesi (set_config, current_setting, pg_* reddedilir); 168 test geçiyor

# Çözüm: Fonksiyon İzin Listesi

*Yasak listesi yerine izin listesi: bilinmeyen her fonksiyon reddedilir*

**İzin verilen**

```
COUNT, SUM, AVG, MIN, MAX, ROUND,
LOWER, UPPER, COALESCE, tarih işlevleri
(ihtiyaç doğdukça listeye eklenir)
```

**Reddedilen**

```
set_config, current_setting, pg_sleep,
pg_read_file, lo_import, dblink, ...
ve listede olmayan her fonksiyon
```

Yasak listesi, listeye girmeyen bir fonksiyonu kaçırır; izin listesi ise bilmediğini reddeder. Doğrulama, RLS ve veritabanı yetkisinin yanında üçüncü bir kat olarak çalışır.

# Giriş Güvenliği ve CORS

*Saldırı yüzeyinin geri kalanı*

### Tek tip 401

Bilinmeyen kullanıcı ile yanlış şifre aynı yanıtı ve benzer süreyi verir; kullanıcı adı sızmaz

### Giriş hız sınırı

Kullanıcı adı başına dakikada sınırlı deneme; aşımda 429

### CORS

allow_origins=* yerine yapılandırılabilir izinli adres listesi (CORS_ORIGINS)

### Gizli değerler

SECRET_KEY geliştirme değeri; gerçek dağıtımda (Hafta 12) değiştirilir, README'de belirtilir

# Değerlendirme (Eval) Seti

*Modelin davranışını tek tek denemek yerine sistematik ölçmek*

## Ne içeriyor

- 65 soru, 4 rol, takip senaryoları dahil
- Tipik sorular: notlar, devamsızlık, isim araması
- Sınır soruları: karşılaştırma, sohbet
- Saldırgan istemler: kural yok say, set_config yaz

## Nasıl çalışıyor

- Gerçek modelle, çalışan API'ye karşı koşulur
- pytest'in parçası değil (anahtar gerekir)
- Her soru için beklenen davranış: sonuç, ret ya da sohbet
- Gerçek değerler truth_sql ile, ton ve dürüstlük yargıçla; çıktı: eval/report.md

# Konuşmalı Asistan Mimarisi

*SQL çeviriciden, araç kullanan bir asistana geçiş*




### Araç sınırı

Bir soru için en çok 3 sorgu. Doğrulama hatasında modele yalnızca kısa, genel bir mesaj gider; veritabanı hata metni gitmez.

### Bağlam

Şema özeti, geçme notu (PASS_GRADE), student_rank ve class_teacher fonksiyonları. Veride olmayan bilgi (program, toplantı) için dürüst cevap.

### Güvenlik

Sohbet geçmişi güvenilmez girdidir; yetki yalnızca JWT ve RLS'ten gelir. Veli/öğrencide toplama sonuçları scope_warning taşır.

# Canlı Testte Bulunan Hatalar (1/3)

*Gerçek zamanlı hata kayıtları: belirti → kök neden → düzeltme*

## 1 Sessizce yanlış sınıf ortalaması

**Doğrulandı (eval)**

**BELİRTİ**

"Ali sınıf ortalamasının üstünde mi?" → Ali 69,79, sınıf da 69,79. Gerçek sınıf ortalaması 74,75 (o günkü seed verisiyle).

**KÖK NEDEN**

Veli hesabında RLS yüzünden yalnızca çocuğun notları görünür; model düz SQL ile "sınıf ortalaması" hesaplayınca yine çocuğun ortalamasını buldu. Hata vermedi, kendinden emin yanlış cevap verdi.

**DÜZELTME**

Prompt: sınıf/okul geneli için yalnızca student_rank. Çalıştırıcı: veli/öğrencide toplama sonucuna scope_warning. Eval: truth_sql ile gerçek değer karşılaştırması.

## 2 Çelişen kurallar: geçme notu

**Doğrulandı (eval)**

**BELİRTİ**

"Geçer notu kaç?" → "veritabanımızda yok, kesin bilgi veremem."

**KÖK NEDEN**

Şema özeti "geçme notu veritabanında YOKTUR" diyordu; okul politikası ise eklenmek isteniyordu. İki kural çelişince model reddetti.

**DÜZELTME**

Geçme notu veritabanı değil okul politikası: PASS_GRADE ayarı (50). Yönetmelik kaynağından 50 doğrulandı; 5'lik dönüşüm doğrulanmadığı için GRADE_LABELS boş.

## 3 Eval denetleyicisi yanlış alarm veriyordu

**Doğrulandı**

**BELİRTİ**

İlk tam koşu 51/64 göründü; çoğu aslında doğru cevaptı.

**KÖK NEDEN**

Sayı dayanağı yalnızca son sorgunun satırlarına bakıyordu ve "74,10" ile 74.1'i farklı sayıyordu.

**DÜZELTME**

Her çalışan sorgu uygulamayla aynı school_app ve RLS bağlamında yeniden çalıştırılıyor; sayılar değer olarak karşılaştırılıyor, satır sayıları da kaynak.

# Canlı Testte Bulunan Hatalar (2/3)

*Kısmen düzelen kayıt da burada, gizlenmiyor*

## 4 Robotik ton, geri çekilen asistan

**Kısmen**

**BELİRTİ**

"Tavsiye veremem" cevapları; kalın başlıklı, madde madde, kalıp kapanışlı cevaplar.

**KÖK NEDEN**

Prompt, güvenlik kaygısıyla fazla çekingendi; sohbet biçimi tanımlı değildi.

**DÜZELTME**

Veriye bağlı kısa destek, rehber öğretmen önerisi, anlayış cümlesiyle açılış, kalıp kapanış yasağı. Açık: model hâlâ nedensellik tahmini yürütebiliyor.

## 5 Model sayımı kendisi yapıyor

**Doğrulandı (eval)**

**BELİRTİ**

60 satırlık listeden "4 öğrenci" diyor; sayı doğru ama kaynağı sorgu değil.

**KÖK NEDEN**

Araç sonucu modele satırları veriyor, ayrı değer sayıları vermiyor; model sayıyı satırlardan çıkarıyor.

**DÜZELTME**

Araç sonucuna sütun başına ayrı değer sayısı (distinct_counts) eklendi; model sayımı satırlardan değil row_count, total_students ve distinct_counts değerlerinden alıyor.

## 6 Eval süreci kör çalışıyordu

**Doğrulandı**

**BELİRTİ**

Eval dakikalarca çıktı vermeden çalıştı; 429 yanıtları başarısızlık gibi sayıldı.

**KÖK NEDEN**

Çalıştırıcı Retry-After'a uymuyor ve ilerleme yazmıyordu.

**DÜZELTME**

429'da bekleyip soru başına en çok 3 deneme; ilerleme satırı; cevap metinleri ve araç çağrıları rapora yazılıyor.

# Canlı Testte Bulunan Hatalar (3/3)

*Veri ve konuşma kalitesi*

## 7 Devamsızlık verisi tutarsız

Doğrulandı

**BELİRTİ**

Ali için kayıtlı toplam 3, attendance'ta devam etmediği 10 kayıt (eski seed verisiyle); asistan çelişen sayılar verdi.

**KÖK NEDEN**

Seed, total_absences ile attendance kayıtlarını birbirinden bağımsız rastgele üretiyordu: 12 öğrencinin 10'unda uyuşmazlık.

**DÜZELTME**

total_absences artık attendance'taki present dışı kayıt sayısı; şema özeti toplamı ve ayrıntıyı tanımlıyor; durum dağılımı SQL'e yaptırılıyor.

## 8 Seed her çalıştığında veriyi değiştiriyordu

Doğrulandı

**BELİRTİ**

Seed yeniden çalışınca Ali'nin ortalaması 69,79'dan 79,05'e, sınıf ortalaması 74,75'ten 76,93'e kaydı.

**KÖK NEDEN**

Tohum sabit değildi ve veri bugünden geriye hesaplanan tarihler içeriyordu; belgelerdeki rakamlar sessizce eskiyebilirdi.

**DÜZELTME**

Veri database/mock_data.json dosyasına donduruldu, tarihler mutlak; seed bu dosyadan yükler. Üç koşuda veri özeti (md5) aynı.

## 9 Öğrenciye veli gibi hitap

Doğrulandı (eval)

**BELİRTİ**

Öğrenci hesabında "çocuğunuzla konuşun" gibi cevaplar.

**KÖK NEDEN**

Asistan promptu role göre hitap tanımlamıyordu.

**DÜZELTME**

Rol bazlı hitap: veliye çocuğunuz, öğrenciye sen, öğretmene öğrenciniz, müdüre tarafsız; eval'de yasak ifade kontrolü.

# Eval Sonucu: 59 / 65

*Tam koşu; düzeltilen maddeler sonradan yeniden koşuldu*

| | | |
|---|---|---|
| `d1` | Yargıç yanlış alarmı: cevaptaki sayımlar veritabanıyla birebir aynı | **Yanlış alarm** |
| `c4` | Küçük model hatası: 73,98 “73” diye kesilmiş (yuvarlanınca 74) | **Bilinen sınırlama** |
| `z2` | Göreli tarih (“dün/bu hafta”): referans tarih eklendi; yeniden koşuda geçti | **Doğrulandı** |
| `m1` | İki dersten biri atlanıyordu: eksiksiz cevap kuralı; yeniden koşuda geçti | **Doğrulandı** |
| `m5` | Açık: duygusal konuda notlardan nedensellik tahmini | **Bilinen sınırlama** |
| `s3` | Denetim fazla katıydı: kural daraltıldı; yeniden koşuda geçti | **Doğrulandı** |

*Süreç dersi: sunucu düzeltmelerden önce --reload olmadan başlatıldığı için eval eski kodu ölçmüştü; yeniden başlatınca z2, m1 ve s3 geçti.*

# Değişen ve Gelişen Teknolojiler

*Bu hafta neyi neyle değiştirdik ve neden*

| Teknoloji | Ne değişti | Neden |
|---|---|---|
| **Araç kullanan asistan (tool use)** | SQL çevirici yerine: model run_sql aracını çağırır, sonucu görür, cevabı doğal dille yazar; son 6 mesaj bağlam olur | Takip soruları, veride olmayan bilgide dürüst cevap, doğal ton |
| **Fonksiyon izin listesi (sqlglot)** | Yasak listesi yerine izin listesi; set_config, current_setting, pg_* reddedilir | Modelin SQL'iyle yetki yükseltme açığı kapandı |
| **SECURITY DEFINER fonksiyonlar** | student_rank ve class_teacher: kimlik oturumdan okunur, başka öğrenci için çağrılamaz | Veli çocuğunun sırasını görür, başkasının verisi açılmaz |
| **Sohbet arayüzü (Streamlit)** | st.chat_message ve st.chat_input; tablo ve SQL açılır bölümlerde | Tablo yerine konuşma deneyimi |
| **Eval seti + LLM yargıç** | 65 soru; truth_sql ile gerçek değer, yargıçla ton ve dürüstlük | Asistan kalitesi tekrarlanabilir ölçülür |
| **Dondurulmuş mock veri** | Rastgele seed yerine database/mock_data.json; tarihler mutlak | Rakamlar ve testler tekrarlanabilir |
| **Yapılandırma ile politika** | PASS_GRADE, REFERENCE_DATE, SHOW_SQL, CORS_ORIGINS ayarları | Okul politikası kodda değil, ayarda |
| **Giriş sertleştirme** | Tek tip 401, kullanıcı başına hız sınırı, izinli CORS adresleri | Kaba kuvvet ve kullanıcı adı sızıntısı |

# Hafta 7 — Kapsam ve Kabul Kriterleri

## Teslim edilenler

- ✓ sql_safety.py — fonksiyon izin listesi
- ✓ Saldırgan istem testleri
- ✓ Giriş: tek tip 401, hız sınırı, CORS_ORIGINS
- ✓ eval/ — soru seti ve çalıştırıcı
- ✓ docs/SECURITY.md — tehdit modeli

## Kabul kriterleri

1. set_config'li SQL reddedilir; teacher hiçbir yolla 4'ten fazla öğrenci göremez
2. Listede olmayan fonksiyon reddedilir, izinliler çalışır
3. Bilinmeyen kullanıcı ve yanlış şifre aynı 401'i verir
4. Giriş denemeleri sınırlanır; CORS yapılandırılabilir
5. Eval seti çalışır ve rapor üretir; testler anahtarsız geçer

# Sonraki Adım — Hafta 8

Veri Bilimi I — Veri ve Keşifsel Analiz

- UCI Student Performance veri setinin incelenmesi
- Keşifsel veri analizi (EDA)
- Özellik mühendisliği
- Henüz model yok: yalnızca veri hazırlığı

*Teşekkürler*